

信息安全测评与 风险评估

任务2：测评方案编制

授课教师：张玉



目录

CONTENTS

- 01 案例导入——“没有方案的测评”
- 02 学习目标
- 03 什么是测评方案？
- 04 测评方案的四大作用

案例导入

某测评机构接到一个三级系统的等保测评任务，项目经理直接带着工具去了现场。

- 无法停机核查：到达后发现对方关键系统正在业务高峰期
- 手忙脚乱：没有提前确定测评对象
- 遗漏要求：测评指标选取不全
- 人员闲置/重复工作：分工不明确
- **客户投诉**：原本3天能完成的工作，拖了7天



思考：这个测评项目出了哪些问题？

讨论：

1. 如果提前编制了详细的测评方案，能否避免这些问题？
2. 一份好的测评方案应该包含哪些内容？

结论 没有方案就去现场 ≈ 没有图纸就去盖房子。

- 学习目标-测评方案

通过本课学习，你将能够：

1

理解测评方案在等保测评工作中的**核心地位与作用**

2

掌握测评方案的**完整结构（六要素）**

3

识记测评方案的**编制流程与方法**

4

能够分析给定系统的**测评范围与测评对象**

5

具备严谨细致的工作**作风与责任意识**

- 什么是测评方案？

目 定义

等保测评方案是测评项目实施前编制的指导性文件，明确“**测什么、怎么测、谁来测、何时测**”等核心问题。

💡 形象的比喻

测评方案就是测评工作的“**施工蓝图**”或“**作战计划**”。
没有方案的测评，就像没有图纸盖房子——结果可想而知。

一句话概括

方案决定质量，细节决定成败。

- 测评方案的四大作用

1. 明确测评范围

防止漏测（遗漏重要系统）和超范围测（做不该做的事）

3. 合理安排日程

提高现场测评效率，避免时间浪费和资源冲突

2. 统一测评方法

保证测评结果客观、公正、可重复、可追溯

4. 项目管理的依据

控制项目进度、成本和质量，是团队协作的“契约”

- 测评方案的“六要素”（核心框架）

记忆口诀：一项依据两范围，三对对象四指标，五定方法六日程，六要素全方案成。

1 项目概述

背景、目的、依据（标准）

2 测评范围

物理位置、网络区域、系统边界

3 测评对象

设备、系统、人员、文档（具体清单）

4 测评指标

对照GB/T 22239的各条款

5 测评方法

访谈、核查、测试

6 日程与人员

哪天做什么、谁来做

要素一：项目概述

要素项	说明/问题	示例
项目背景	为什么要做这个测评？	为贯彻落实《网络安全法》及等保2.0要求，XX单位委托我机构对其核心业务系统开展等级保护测评工作。
委托单位	谁委托的？	XX市人力资源和社会保障局
被测系统名称	测什么系统？	XX市人社公共服务平台
安全保护等级	几级？	第三级（S3A3）
测评目的	要达到什么目标？	通过测评，全面掌握系统安全状况，发现与等级保护标准的差距，提出整改建议。
测评依据	依据什么标准？	等保标准



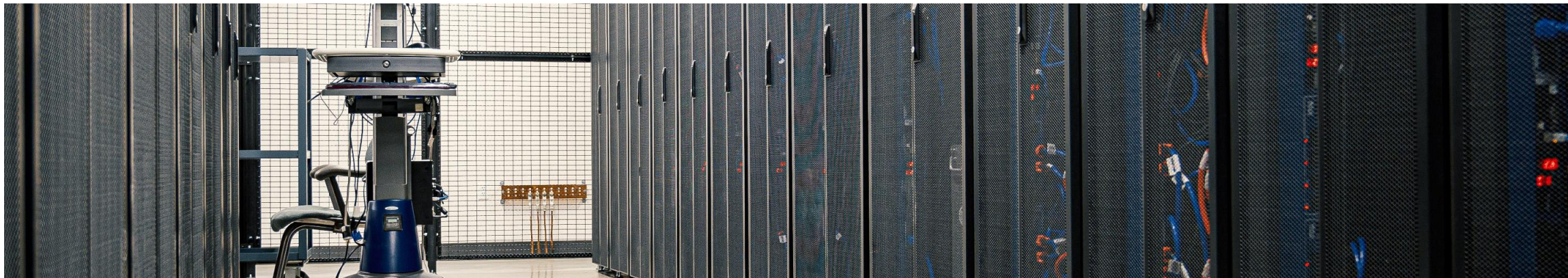
思考：哪里不合适？

要素一：项目概述

要素项	说明/问题	示例
项目背景	为什么要做这个测评？	为贯彻落实《网络安全法》及等保2.0要求，XX单位委托我机构对其核心业务系统开展等级保护测评工作。
委托单位	谁委托的？	XX市人力资源和社会保障局
被测系统名称	测什么系统？	XX市人社公共服务平台
安全保护等级	几级？	第三级（S3A3）
测评目的	要达到什么目标？	通过测评，全面掌握系统安全状况，发现与等级保护标准的差距，提出整改建议。
测评依据	依据什么标准？	GB/T22239-2019、GB/T28448-2019等

⚠️ 常见错误：只写“依据等保标准”，不写具体标准编号和名称。✖

- 要素二：测评范围



物理位置

覆盖哪些物理场所？

示例：XX数据中心A栋3楼机房、XX办公楼网络机房

网络区域

覆盖哪些网络区域？

示例：互联网接入区、核心业务区等

系统边界

测评的起点和终点？

示例：从互联网入口到数据库存储，包含Web、应用、数据库服务器

- 要素三：测评对象（重点）

测评对象是“测什么”的具体清单，必须可量化、可追溯。

分类	包含内容	数量/举例
网络设备	路由器、交换机、负载均衡等	核心交换机2、汇聚交换机4
安全设备	防火墙、堡垒机、WAF、IDS/IPS等	防火墙2、堡垒机1、WAF1
主机设备	Windows/Linux服务器	Web服务器3、应用服务器2、数据库服务器2
数据库	关系型数据库、NoSQL等	MySQL2、SQLServer1
应用系统	Web应用、移动App等	XX市人社公共服务平台网站
管理制度	安全管理制度文档	安全管理制度汇编（1套12份）
人员	管理员、操作员、负责人等	系统管理员2、安全管理员1

- 测评对象选取四大原则



1. 应测尽测

凡是标准中明确要求的对象，都应纳入

（举例：标准要求检查“网络设备”，则所有核心网络设备必须纳入）



2. 关键性原则

承载核心业务、存储重要数据的设备，必须选取

（举例：核心数据库服务器必须100%纳入，不可抽样）



3. 代表性原则

同一类型的多台设备中，选取最有代表性的

（举例：同型号、同配置的5台服务器中选取2台（配置最高/流量最大））



4. 抽样原则

同类设备、同质化配置，可抽样测评（不低于30%）

（举例：10台同型号交换机，至少抽检3台）

- 要素四：测评指标

测评指标 = “按什么标准来检查”

来源：直接来源于 GB/T 22239 对应等级要求项。

选取步骤

- 1

确定被测系统安全保护等级(如第三级)
- 2

查阅GB/T 22239对应等级的“安全通用要求”
- 3

逐条对照，确定哪些指标适用、不适用

≡ 示例：第三级 — 身份鉴别

要求项	要求内容	状态
a)	应对登录用户进行身份标识和鉴别，标识具唯一性，鉴别信息具复杂度并定期更换	☑适用
b)	应具登录失败处理功能，配置结束会话、限非法登录次数和超时自动退出	☑适用
c)	远程管理时，应采取必要措施防止鉴别信息在网络传输中被窃听	☑适用
d)	应采用口令、密码、生物等两种或以上组合技术进行身份鉴别	☑适用 (三级增强)

- 测评指标的裁剪

不是所有标准条款都适用于每一个系统——“裁剪”是指在不适用时说明理由后剔除。

可以裁剪的情况

- 系统不涉及该技术领域（示例：系统没有无线网络，则“无线接入控制”指标可不适用）
- 系统不存在该物理设施（示例：系统部署在云上，无物理机房，则“物理位置选择”可不适用）
- 系统不处理该类数据（示例：系统不涉及个人信息，则“个人信息保护”部分指标可不适用）

裁剪要求

- ☒ 必须逐条说明不适用理由
- ☒ 理由应具体、有说服力

禁止做法

- ✗ 不能随意裁剪核心指标

- 要素五：测评方法（三种方法）

访谈

与管理人员、运维人员面对面交流。

适用场景：安全管理、人员配置、制度执行。

示例：询问安全管理员：“贵单位的密码策略是如何设置的？”

核查

上机查看配置、查阅文档、实地检查。

适用场景：技术配置核查、制度文档审查。

示例：登录服务器查看/etc/login.defs文件中的密码策略设置

测试

使用工具进行漏洞扫描、配置核查等。

适用场景：脆弱性发现、配置合规性。

示例：使用Nessus对目标IP进行漏洞扫描，使用配置核查工具检查基线

- 要素六：日程安排与人员分工

日程安排示例（5天测评周期）

阶段	日程安排	人员分工
第1天	项目启动会（客户对接、确认范围）；安全物理环境现场核查、安全管理文档查阅	全体成员
第2天	网络设备核查；安全设备核查	A组：小王
第3天	主机安全基线核查；数据库安全配置核查	B组：小李
第4天	应用系统安全功能验证；漏洞扫描	C组：小张
第5天	补充核查、总结会；项目撤离	全体成员

人员分工

角色	姓名	职责描述
项目经理	张工	项目总体协调、进度管理、质量控制
测评工程师A	王工	安全物理环境、网络设备、安全设备测评
测评工程师B	李工	主机安全、数据库安全测评
测评工程师C	赵工	应用系统安全、漏洞扫描与分析

- 方案格式要求与常见错误

格式要求

 使用正式公文格式，字体统一，页码规范

 所有引用的标准必须标注标准编号和名称

 日期、人数、设备型号等信息必须具体明确

 不得出现“若干”“一些”“大概”等模糊表述

常见错误对照表

常见错误()	正确写法()
依据等保标准	依据GB/T22239-2019《信息安全技术网络安全等级保护基本要求》
预计需要2-3天完成	现场测评时间为2026年9月15日至9月19日，共计5个工作日
对服务器进行核查	对Web服务器（IP:192.168.1.10-192.168.1.12，共3台）进行安全基线核查
发现配置不当的问题	防火墙策略中，进站规则第5条允许任意源IP访问管理端口（22/tcp）

- 方案编制的职业品格

三个关键词：



依据标准、基于事实、系统分析；不凭经验办事，不主观臆断。



每一个字、每一个数字都要准确；每一个判断都要有依据。



方案决定了整个项目的走向；方案的质量代表着测评团队的专业水平。

一句话：一份好的方案，体现的是测评团队的职业态度和专业水准。精益求精，是对客户负责，也是对自己负责。

- 知识点回顾

测评方案结构学习

1 测评方案的定义与作用

定义：测评工作的“施工图”

作用：明确范围、统一方法、安排日程、管理项目

2 测评方案六要素

项目概述、测评范围、测评对象、测评指标、测评方法、日程与人员

3 测评对象选取原则

应测尽测、关键性、代表性、抽样
(抽样比例 $\geq 30\%$)

4 格式要求

规范、具体、明确
常见错误与正确写法对照